K.A.R.M.A · VIVA PREPARATION

KARMA Viva Q&A

Short answers to likely viva questions. Each answer is two or three sentences you can say aloud, followed by **Proof:** where to point the examiner (report section, slide or live demo). Keep answers short, then offer to show it. If you don't know, say what you would check and where.

Team K.A.R.M.A · The Oxford Evening Polytechnic · Semester VI Diploma Major Project

About the project

What is KARMA, in one sentence?
A honeypot platform that runs fake SSH, web, FTP, Telnet and RDP servers, records everything an attacker does, maps each action to MITRE ATT&CK with a 0–100 risk score, and automatically quarantines high-risk attackers, all shown live on a dashboard. Proof: live demo; slides 8 and 14.

Why a honeypot instead of a firewall or IDS?
A firewall only blocks what it already knows is bad, and a stolen password looks legitimate. Nobody has a reason to touch a decoy, so every connection to it is suspicious; that gives very few false positives. Proof: slides 6–7; Verizon DBIR 2025 (22% of breaches start with stolen credentials).

What is new compared with Cowrie, T-Pot or Wazuh?
Cowrie is an SSH/Telnet honeypot that only writes logs. T-Pot needs a Linux server running Docker and doesn't contain attackers. Wazuh is a SIEM with no decoys. KARMA combines decoys, SIEM view, MITRE mapping, auto-quarantine and an AI analyst in one Python process on one laptop. Proof: slide 11; report references 6 and 9.

What if the attacker realises it's a honeypot?
That is a real limit of every honeypot. We reduce it with a realistic Ubuntu banner, a fake company file system, believable documents and a leaked deploy file. Even an attacker who leaves early has already shown their IP, tools and first commands, which is the intelligence we want.

Who would use KARMA?
Small organisations and college labs that cannot afford a commercial deception product, and teaching labs for cyber-security students. Proof: report Chapter 5 (business options) and section 6.5.

What does the name mean?
In security, "karma" is an attack that comes back to its sender: the attacker's own actions expose them. The letters also stand for the team (Kanaka, Abhijeet, Raghunandan) plus Monitoring & Active cyber deception. Proof: slide 9.

Security and ethics

Can the attacker escape your fake shell and attack the real PC?
No. The shell is simulated in Python: it answers from an in-memory fake file system and never calls the operating system. Pipes, redirection, running programs, installs and outbound connections are refused, uploads are rejected, and sessions end after 15 minutes. Proof: slide 20; automated tests for host files, path traversal and execution.

Can the attacker reach the dashboard?

No. The dashboard on port 8000 accepts only connections from the KARMA PC itself and needs a 43-character admin token; sessions expire after 8 hours. The tunnel never exposes port 8000. Proof: TC-13 (outside request gets HTTP 403).

Is this legal and ethical?

We only run decoys on our own lab PC and networks we control, and nothing is done to the attacker's machine. The data is synthetic (fake company, fake keys), captured passwords are redacted, and the README warns to enable sensors only on networks you administer. In India, CERT-In directions and the DPDP Act 2023 apply to logs that contain personal data. Proof: report references 2 and 12.

What do the macros in the AEGIS documents do?

If the reader enables content, the macro only runs on the reader's own PC: it writes a greeting text file and opens it in Notepad, then opens PowerShell running `whoami`. It makes no network connection, installs nothing and does not persist. It demonstrates why opening documents from untrusted sources is dangerous. The alert to KARMA comes from the download, not from the macro.

Aren't you sending data to third parties?

Only two optional services: the attacker's IP to ip-api.com for city-level location, and, only if a DeepSeek key is set, the event summary to DeepSeek. Both can be turned off, and the offline analyst still works. Proof: README section "Truthful analysis and privacy".

Could KARMA itself be used to attack someone?

No. It only listens and answers on its own ports. The optional firewall blocking only adds block rules on the KARMA PC.

Design and technology

Why Python, FastAPI and SQLite?

Python has Paramiko, a real SSH server library, so attackers' own SSH clients are fooled. FastAPI gives the REST API and WebSockets for live updates in one process. SQLite needs no database server, which suits a single laptop; it runs in WAL mode so sensors can write while the dashboard reads. Proof: slide 15.

Why not a bigger database?

One honeypot produces thousands of events, not millions, so SQLite is enough. KARMA keeps about 100,000 events and prunes older ones. PostgreSQL or Elasticsearch is in our future scope for large deployments.

How does the MITRE mapping work, and how accurate is it?

It is rule-based: each rule has keywords and the decoy services it applies to, for example `whoami` on SSH gives T1059 and `UNION SELECT` on the web gives T1190. It recognises 6 techniques: T1046, T1059, T1078, T1110, T1190 and T1595. It is deterministic and explainable but can miss attacks phrased in unexpected ways; smarter analytics is in the future scope. Proof: TC-02; slide 13 live.

How is the risk score calculated?

Each technique has a base risk (for example T1059 is 90, a honeytoken is 95). Repeated attempts add 5 points each, up to +30, capped at 100. A low-risk event such as a scan is capped at 74, so repetition alone never quarantines anyone. 75 or more triggers quarantine in Contain mode. Proof: report Eq. 3.1; TC-01.

What is the difference between Contain and Observe mode?

Contain quarantines an attacker as soon as a high-risk action happens. Observe logs everything but never blocks, for rehearsals and for studying an attacker for longer.

How does geolocation work?

Local and lab IPs (192.168.x, 10.x, 127.0.0.1) show the configured lab location, Bengaluru. Public IPs are looked up on ip-api.com once, when the event is logged, cached for a day and stored with the event. Offline, they show as Unknown. It is approximate: a VPN shows the provider's location.

What are honeytokens?

Fake secrets planted to be stolen: an AWS-style API key, an admin URL and a staging password in `deploy.env`. Nobody legitimate knows them, so any use proves theft. Using one is mapped to T1078 with risk 95 and quarantines the attacker. Proof: TC-06; demo finale.

How does the internet tunnel work?

KARMA has a built-in client for the free bore.pub server. KARMA connects out, so no router port forwarding is needed, and each decoy gets a public address. The limit is that tunnelled attackers appear as 127.0.0.1.

Testing, limitations and future scope

How did you test it?

With 14 system test cases (TC-01 to TC-14) run against the live platform, all passed: risk scores, MITRE mapping, each decoy, honeytokens, quarantine, a burst of 25 probes, CSV audit, API consistency, phishing, AI copilot, dashboard access and decoy toggling. Automated regression tests also run on Windows and Linux for every change, plus a dependency security audit. Proof: report Chapter 4; slide 21.

Give one example test.

TC-07: an attacker scoring 75 or more is quarantined automatically; then we manually block and unblock 203.0.113.77 and check the dashboard reflects each action.

What are its limitations?

One laptop and one SQLite file, not a distributed SIEM. Rule-based detection that a careful attacker can phrase around. City-level, approximate geolocation. Tunnelled attackers all appear as 127.0.0.1. One admin token, no user roles. Proof: slide 23.

What would you do next?

From report section 6.4: firewall integration (a first opt-in version now exists), distributed sensors, scalable storage, richer decoys (SMB, MySQL, Redis), Syslog/CEF and STIX export, smarter analytics, a local AI model, and role-based access.

What was the hardest part?

Making the fake SSH server convincing to a real SSH client while guaranteeing nothing ever runs on the host, and keeping the live dashboard fast when many events arrive at once.

Demo troubleshooting

Problem in the hall	Quick fix	What to say
Before you start	Press **Reset System**: clears data, unblocks every IP, sets Contain	"Starting from a clean state."
Attacker can't connect	Same hotspot? Right IP? Check the attacker isn't blocked in Attacker Profiles	"The trap is so strict it blocked our test machine; unblocking it now."
SSH says Connection reset	That IP is quarantined; press Unblock	"That's containment working."
No internet	The dashboard still works; maps show country outlines; IPs show Bengaluru or Unknown	"KARMA is designed to run offline."
Defender blocks the AEGIS file	Skip opening it; show the Decoy file read alert	"The download itself is the alarm."
bore.pub tunnel fails	Use the same-hotspot setup instead	"The internet relay is optional."
Anything else	Play the backup recording	"Here is the same attack, recorded this morning."

After each attack, open

▶ Replay
to walk through the attacker's session and 📄 **Report** to show the printable incident report.